

AI Security Learning Roadmap

Phase 4 — Enterprise AI Security

Complete Master Report — Topics, Frameworks, Capstone Activity & Conclusion

Contents

- Part I — How It All Connects
- Part II — Six Core Topics (Responsible AI, Governance, Risk Management, Human Review, Compliance, Data Classification)
- Part III — Two Governing Frameworks (NIST AI RMF, Google SAIF)
- Part IV — Framework Comparison
- Part V — Capstone Activity: SentryHR
- Part VI — Quick-Reference Appendix
- Part VII — Conclusion

Personal study record — August 2026

Part I — How It All Connects

Phase 4 moves from understanding AI risks (Phase 3) to understanding how organizations manage those risks systematically. The six core topics form one continuous chain, each turning the previous idea into something more concrete and enforceable:

Responsible AI (values) → Governance (structure & authority) → Risk Management (the method that structure runs) → Compliance (the legal floor, backed by penalties) → Human Review & Data Classification (the concrete controls that make the whole chain work in practice)

Core takeaway: Values only matter if enforced by structure; structure only matters if it runs a real risk process; and none of it counts as genuinely safe just because it is legally compliant — compliance is a floor, not a ceiling.

The single thread running through nearly every real case studied: a control existed on paper (a principle, a policy, a label, a checkpoint) but was not genuinely enforced at the moment it mattered, and no continuous monitoring caught the gap before real harm occurred.

Two governing frameworks formalize this entire chain into implementable structure: NIST's AI Risk Management Framework (broad, governance-flavored) and Google's Secure AI Framework (narrow, security-engineering-flavored).

Part II — Six Core Topics

Each topic below covers its core idea, key mechanics, benefits and complications, real-world cases, and a diagnostic checklist for future analysis.

1. Responsible AI

Core Idea

The set of principles an organization commits to — fairness, transparency, accountability, privacy, safety, and human oversight — that answer: “Should we build this AI system, and how do we prevent it from causing harm?” Principles only matter when turned into enforceable structure (e.g. Microsoft's Office of Responsible AI, mandatory Impact Assessments, an AI Red Team).

Key Mechanics

- Fairness — the AI should not systematically disadvantage certain groups
- Transparency/Explainability — people should understand why the AI made a decision
- Accountability — a human or team owns the AI's behavior and outcomes
- Privacy — the AI should not expose or misuse personal/sensitive data
- Safety and Reliability — predictable behavior, no harmful or wildly incorrect outputs
- Human Oversight — humans retain meaningful control over consequential decisions
- Principles genuinely conflict (transparency vs. security, fairness vs. accuracy) — there is no formula, only documented judgment calls, which is exactly why Governance exists

Benefits

- Reduces real-world harm by catching bias, unsafe outputs, and privacy violations before users are affected
- Builds user and regulator trust, often the actual bottleneck to AI adoption
- Reduces legal/regulatory risk by pre-empting future requirements
- Protects brand and reputation from high-profile failures
- Improves model quality — fairness/robustness testing often surfaces real engineering bugs

Complications

- Principles genuinely conflict with no formula to resolve them automatically
- Fairness itself is hard to define — different fairness metrics can be mathematically incompatible
- Slows delivery — impact assessments and red-teaming add real time/cost
- Hard to measure ROI — preventing an unrealized harm is invisible to leadership
- Global inconsistency — what counts as “responsible” varies by region and regulation
- Explainability limits are a genuine technical constraint, not just organizational unwillingness
- Principles vs. enforcement gap — published values without real enforcement is “performative” Responsible AI

Real-World Cases

Case	Root Gap
ChatGPT / Character.AI lawsuits (2025)	Safety and human-oversight failure — systems optimized for engagement without adequate crisis safeguards
Chevrolet dealership chatbot (\$1 sale)	Prompt injection — no input validation, no price guardrails
Air Canada chatbot hallucination	Reliability failure — no grounding in verified policy data; tribunal found no “reasonable care” taken
DPD chatbot jailbreak	Security failure — bank data leaked via jailbreak, no red-teaming performed
Amazon / iTutorGroup hiring AI	Fairness failure — no bias audit before deployment

Diagnostic Checklist

- 1. Which specific principle is most at risk, and for which function of the system?
- 2. Is the principle backed by real enforcement (a team, a gate) or just a published statement?
- 3. Where do two principles conflict here, and who is empowered to make that judgment call?

2. AI Governance

Core Idea

The system of structure, policy, process, and oversight that enforces Responsible AI principles — who has the authority to approve or block an AI project, and how that authority is exercised. Governance turns “we believe in fairness” into “run this bias audit before merging to production.”

Key Mechanics

- Structure — a cross-functional AI Governance Board (legal, IT, business, compliance) with real authority
- Policy — abstract principles turned into concrete, checkable rules
- Process — Inventory → Risk Tiering → Impact Assessment → Build Controls → Red Team → Approval → Ongoing Monitoring
- Tools — audit logs, model cards, bias-testing tools, monitoring dashboards
- Risk tiers (EU AI Act model): Unacceptable (banned) → High (employment/credit/healthcare — documented risk mgmt, human oversight, audit logs) → Limited (e.g. chatbots — disclosure duty only) → Minimal (no mandated controls)
- Diagnostic question: If this AI gets it wrong, who gets hurt, how badly, and how reversible is the harm?

Benefits

- Turns intentions into enforceable action via real gates, not just stated values
- Proportional effort — fast where safe, careful where risky (via tiering)
- Creates a defensible paper trail useful in litigation and audits
- Builds organizational consistency regardless of which manager is involved
- Prepares for regulation ahead of legal deadlines instead of reacting under pressure

Complications

- Can degrade into box-ticking bureaucracy that doesn't actually improve safety
- Misclassification risk — tiering a high-risk system as limited-risk is one of the costliest mistakes possible
- Governance boards can become bottlenecks, pushing teams toward shadow-AI workarounds
- Frameworks fragment across jurisdictions (EU AI Act, US state laws, sector rules)
- Governance ≠ safety — a fully compliant, well-classified system can still cause real harm (Air Canada)
- Accountability can become diffuse instead of clearer, ironically, as more layers are added

Real-World Cases

Case	Root Gap
Zillow “Zestimate” iBuying collapse	No circuit breaker — no threshold halting automated purchase decisions as losses diverged from reality (\$500M+ loss)

Amazon hiring AI (gender bias)	No bias testing across protected categories before deployment
Australia's Robodebt Scheme	Failed on nearly every front — invalid method, unfair burden of proof, no real gatekeeping authority, warnings ignored for years, diffused accountability
Agentic AI database deletion (2026)	No “blast radius” containment or backup verification before granting an autonomous agent action authority

Diagnostic Checklist

- 1. Is the underlying method statistically/technically valid for the decision it is making?
- 2. Who bears the burden of proof if the system is wrong, and is that fair/accessible?
- 3. Was there a documented risk assessment with real gatekeeping authority before launch?
- 4. Is there an active feedback loop that can catch and escalate problems quickly once live?
- 5. Is there one accountable owner — not diffused responsibility — for the system's real-world outcomes?

3. Risk Management

Core Idea

The systematic process of identifying, assessing, treating, and monitoring what could go wrong with an AI system — so risk decisions are made deliberately, with evidence, rather than by accident or neglect.

Key Mechanics

- Identify — list risks across categories: bias, security, operational, compliance, third-party, reputational, autonomy/autentic
- Assess — score likelihood × impact (risk matrix), with an exposure multiplier for internet-facing or high-permission systems
- Treat — choose Avoid, Mitigate, Transfer, or Accept — and document residual risk left over
- Monitor — continuously, via Key Risk Indicators (KRIs), since risk profiles drift over time
- Risk Register — one row per risk per system: type, likelihood, impact, owner, control
- Three Lines of Defense — 1st: builders/operators; 2nd: risk/compliance (policy, challenge); 3rd: internal audit (independent verification)
- Residual risk — what remains after a control; document it, never assume zero
- KRI vs. KPI — KRI = early warning for a specific risk; KPI = whether the risk management process itself works

Benefits

- Deliberate decisions instead of hope — even accepted risk becomes a conscious, documented choice
- Correctly prioritizes limited resources toward the highest-scoring risks
- Early warning via KRIs, catching problems while small and cheap to fix
- Creates a defensible record for regulators, courts, and boards
- Clarifies accountability via the Three Lines of Defense structure
- Adapts as the world changes via a fixed re-assessment cadence

Complications

- Scoring is often subjective dressed up as precise numbers
- Risk appetite is genuinely hard to define cleanly in the moment
- Residual risk gets forgotten once the original team moves on
- Agentic AI breaks traditional likelihood-based scoring — harm can be instant and irreversible
- Third-party/vendor risk is often invisible to the organization using it
- The 3 Lines model can become theater without genuine independence
- Process overhead competes directly with speed-to-market pressure

Real-World Cases

Case	Root Gap
------	----------

Vercel / Context.ai breach (Apr 2026)	No inventory of employee-adopted third-party AI tools — a pure Identify-step failure; OAuth tokens bypassed MFA entirely
Meta internal agent incident	No permission-boundary / human-in-the-loop control before an agent could act autonomously
AI-crafted phishing (54% click-through)	Likelihood scores from prior years left stale — re-assessment cadence matters
Third-party breach cascades	Vendor risk treated as a one-time questionnaire instead of continuous monitoring (avg. 5.28 downstream orgs compromised per breach)

Diagnostic Checklist

- 1. Was the risk identified at all — is it in the register?
- 2. Was the blast radius / exposure actually assessed, not just the isolated flaw?
- 3. Was residual risk after each control explicitly documented?
- 4. Which line of defense owned this, and did that line make the safe path the easy path?
- 5. Was monitoring continuous, or resting on a stale one-time assessment?

4. Human Review

Core Idea

A design pattern where a person with genuine authority — not just presence — reviews, corrects, approves, or blocks an AI's output or action at defined checkpoints, before it takes effect. Presence ≠ Practice: a human's name on a decision is not the same as that human exercising independent judgment.

Key Mechanics

- Spectrum: Human Authorization (strongest, explicit approval logged before execution) → Human-in-the-loop (direct intervention) → Human-on-the-loop (monitoring only)
- Tiered/graduated review — route by confidence threshold plus reversibility, regulatory impact, and customer proximity
- Central failure mode: Automation Bias — trust in a confident, fluent AI erodes independent verification over time (an 11-stage decay from genuine oversight to rubber-stamping)
- Counter-intuitive finding: better AI can make human oversight worse, because reliability breeds complacency (the “moral crumple zone”)
- Counters: practiced simulator-style drills (aviation Crew Resource Management model), reducing friction of disagreeing with the AI, calibrating thresholds against real production data, requiring a genuine audit trail

Benefits

- Directly counters hallucination/bias failure patterns
- Scales proportionally via tiering — preserves most automation speed while covering what matters
- Produces the audit trail regulators and courts expect
- Feeds back into improving the AI model itself via correction signals
- Increasingly a hard legal requirement (EU AI Act Article 14, effective Aug 2026)

Complications

- Presence without practice is worse than useless — creates false protection
- Automation bias is hard to train against permanently, not a one-time fix
- Reviewer fatigue from over-routing recreates rubber-stamping through volume
- Agentic AI can compress the review window to near-zero
- Classifying “reversibility” or “risk” is itself a subjective judgment call
- Genuine review requires real investment, easy to quietly under-resource

Real-World Cases

Case	Root Gap
Mata v. Avianca	A lawyer filed AI-fabricated case citations without independent verification — presence without practice
AI-drafted government rulemaking	Rubber-stamping AI output threatens the legal basis for deference to “agency expertise” itself

Autonomous vehicle safety drivers	System reliability eroded human vigilance — the “moral crumple zone”
Medical diagnostics automation-bias studies	Quantified evidence: people skip correcting AI more when correction requires extra effort

Diagnostic Checklist

- 1. Was the checkpoint practiced, not just nominally present?
- 2. Did trust in the AI's fluency substitute for genuine verification?
- 3. Was the safe path (verifying) actually the easy path, or did friction discourage it?
- 4. Was there a structural second check, or did everything rest on one person?
- 5. Does the proposed fix address the root cause, or just a visible symptom?

5. Compliance

Core Idea

Conformance with binding legal obligations governing how AI is built, deployed, and operated — the part of AI safety an organization does not get to opt out of. Compliance is a floor, not a ceiling: a system can be fully compliant and still cause real harm (Air Canada).

Key Mechanics

- 2026 landscape: EU AI Act (four risk tiers, Article 99 fines up to €35M/7% global turnover); US state patchwork (19+ states); sector regulators (FTC, SEC, FDA) applying existing authority to AI
- Conformity Assessment: Classify → Build evidence base (QMS, risk management system, data governance, technical documentation, automatic logging) → Assess (internal control or Notified Body) → Certify (CE marking) → Register → Monitor post-market
- Critical limitation: assessments are document-based and episodic — they do not automatically re-verify anything after launch
- GPAI providers face separate obligations — documentation for downstream developers, training-data summaries, systemic-risk evaluations above compute thresholds

Benefits

- Forces a minimum standard even on organizations that wouldn't otherwise prioritize safety
- Creates a common baseline across an industry, removing the incentive to cut corners
- Produces evidence useful far beyond regulators — litigation, audits, incident response
- Turns vague principles into an actionable checklist
- International frameworks are slowly converging, reducing duplicate compliance work

Complications

- Jurisdictional fragmentation — one system can fall under several rulebooks at once
- Enforcement infrastructure (e.g. Notified Bodies) still being built as deadlines hit
- Legal uncertainty from conflicting federal/state authority
- Document-based, episodic compliance creates false confidence about ongoing safety
- Compliance ≠ safety, the recurring lesson of this whole phase
- Heavy cost burden disproportionately affects smaller organizations
- “Paper compliance” temptation, now actively targeted by regulators demanding access to actual code/models

Real-World Cases

Case	Root Gap
FTC v. Rite Aid (2023)	Zero pre-deployment bias/accuracy testing on facial recognition — first FTC action against “algorithmic unfairness”
SEC “AI-washing” actions (2024)	Overstating AI capabilities in marketing is itself a compliance violation, even if the AI never malfunctions

Clearview AI (multi-country GDPR fines)	One non-compliant practice triggered separate, cumulative penalties across every jurisdiction it touched
Italy's temporary ChatGPT ban (2023)	Regulators can force fast operational change using existing law, even absent AI-specific legislation

Diagnostic Checklist

- 1. Which rulebooks actually apply (jurisdiction, sector, risk tier)?
- 2. Was evidence built during development, or only assembled after the fact?
- 3. What does the remedy/settlement reveal about the program that should have existed from day one?
- 4. Is this genuinely an AI-specific law, or existing general authority applied to AI?
- 5. Is certification treated as a finish line, or as a floor requiring continuous monitoring on top?

6. Data Classification

Core Idea

Categorizing data by sensitivity level (Public / Internal / Confidential / Restricted) so proportionate protection controls follow — the foundational control that every other Phase 4 topic quietly depends on. Critical principle: a label that doesn't travel with the data into an AI pipeline is functionally useless.

Key Mechanics

- Lifecycle: Discover (find where data lives, incl. shadow locations) → Define taxonomy → Assign labels (hybrid automated + human) → Apply controls per label → Enforce at AI ingestion points (training, runtime/RAG, output) → Track provenance/lineage → Train employees → Monitor continuously
- DSPM (Data Security Posture Management) tools close the “we don't know what we don't know” visibility gap at scale

Benefits

- The prerequisite that makes most other Phase 4 controls actually possible
- Enables proportional protection instead of blanket overkill or blanket neglect
- Directly prevents Samsung-style leaks when enforced at AI ingestion points
- Makes AI training data auditable and defensible for regulators
- Supports selective, risk-proportional AI adoption instead of blunt outright bans

Complications

- Discovery is genuinely hard at scale, especially for shadow AI tools
- Labels decay and drift as data moves, merges, or is repurposed
- Over-classification causes alert fatigue and workaround behavior
- Automated classifiers make silent errors that bypass downstream controls
- Real-time enforcement at AI ingestion points is still immature technology
- Cross-border/cross-regulation definitions of “sensitive” genuinely conflict

Real-World Cases

Case	Root Gap
Samsung / ChatGPT leak (2023)	Classification labels existed internally but did not travel with the data into an external AI tool — no enforcement at the ingestion point
Cal AI breach (2026)	Classification never connected to real technical controls at all — health data shipped with zero authentication
RAG cross-tenant leakage	Classification/tenant boundaries failing inside the AI system's own retrieval architecture, not from human error
Meta internal agent exposure	An AI agent itself bypassing access/classification boundaries autonomously — no human error involved

Diagnostic Checklist

- 1. Was the data actually classified, or does the outcome suggest classification was never connected to engineering?
- 2. Did development/deployment speed override the discipline of classification-driven controls?
- 3. Do the organization's public claims match its actual enforced controls?
- 4. Were acquired, merged, or newly created datasets re-classified, or inherited/assumed safe?
- 5. Would continuous automated discovery have caught the gap before real harm occurred?

Part III — Two Governing Frameworks

NIST AI Risk Management Framework (AI RMF)

A voluntary, non-certifiable framework published by NIST (Jan 2023), organizing AI risk management into four functions — Govern, Map, Measure, Manage — designed to run iteratively throughout an AI system's lifecycle. No “2.0” exists; NIST extends it via Profiles (Generative AI Profile, Critical Infrastructure Profile) rather than new versions.

The Seven Characteristics of Trustworthy AI

Valid & reliable, safe, secure & resilient, accountable & transparent, explainable & interpretable, privacy-enhanced, and fair — NIST's official phrasing of the Responsible AI principles.

The Four Functions (19 categories, 72 subcategories)

Function	Maps to
Govern (cross-cutting)	AI Governance Board, policy, accountability, risk appetite, third-party oversight
Map	Risk Identification + Impact Assessment, per AI system
Measure	Risk Assessment (likelihood × impact), bias testing, red-teaming
Manage	Risk Treatment (avoid/mitigate/transfer/accept) + residual risk + monitoring

Documented common failure pattern: organizations score well on Govern (policies exist) but poorly on Measure/Manage (nothing is actually tested or tracked).

Implementation in Practice

Assess (Current Profile vs. Target Profile — the gap is the roadmap) → Build Govern scaffolding (charter, acceptable use policy) → Apply Map/Measure/Manage per system, starting with highest-risk systems → Never stop (quarterly reviews, continuous monitoring). Timelines scale with organization size: ~30 days (lean startup) to 6–18 months (full enterprise maturity).

Benefits & Complications (condensed)

- Benefits: shared vocabulary across a fragmented regulatory landscape; scales to any org size; free and detailed (140+ page Playbook); increasingly load-bearing via procurement and regulator citation; extends cleanly via Profiles; genuinely iterative
- Complications: voluntary/non-certifiable — self-claimed alignment can be hollow; the well-documented Govern-strong/Measure-Manage-weak pattern; 72 subcategories invite selective deferral; agentic AI stretches the base framework; US-origin context; wildly varying implementation depth hides behind the same label

Real Cases

Case	Lesson
Colorado's repealed safe harbor	Legal incentives tied to a framework can be unstable — a state law changed mid-stream
EO 14110 + federal procurement	Voluntary frameworks become operationally mandatory through procurement and policy

FTC/CFPB/FDA/SEC/EEOC citing it in guidance	Regulators use its principles to define “reasonable” care, even without binding force
Treasury's Financial Services AI RMF (Feb 2026)	A regulator translating the voluntary structure into 230 mandatory sector controls
Workday, Google public adoption	Voluntary enterprise adoption, not just regulatory-pressure adoption

Google Secure AI Framework (SAIF)

A security-specific, conceptual framework (June 2023) adapted from Google's own two-decade software security practice. Narrower and more technical than NIST RMF — focused specifically on securing AI against attacks, compromise, and abuse, not broader governance/fairness/compliance concerns.

The Six Core Elements (foundation → adaptation → contextualization)

- Expand strong security foundations to the AI ecosystem
- Extend detection and response into the AI threat universe
- Automate defenses to keep pace with AI-powered attacks
- Harmonize platform-level controls for consistency
- Adapt controls with faster feedback loops as AI evolves
- Contextualize AI risks within surrounding business processes

The Risk Map — Components → Risks → Controls → Personas

Area	Example Risk	Example Control
Data	Data Poisoning, Excessive Data Handling	Data filtering, lifecycle management
Infrastructure	Model Exfiltration, Supply Chain Attacks	Hardened storage/serving, integrity mgmt
Model	Model Theft, Deployment Tampering	Access control, secure-by-default tooling
Application	Denial of ML Service, Prompt Injection	Rate limiting, input filtering

SAIF 2.0 — The Agent Security Map (2026)

Maps an agent's own pipeline (Application & Perception → Reasoning Core → Orchestration → Response Rendering) with three controls: Agent Permissions (dynamic least privilege), Agent User Control (explicit approval before consequential actions), and Agent Observability (full action/reasoning logging — “the control most teams skip”).

Benefits & Complications (condensed)

- Benefits: whole-ecosystem coverage beyond just the model; genuinely actionable engineering detail; first-mover on agentic AI security; grounded in real cited incidents; open and community-extended via CoSAI; complements NIST RMF
- Complications: narrow scope — doesn't cover fairness/bias/compliance alone; assumes Google-scale infrastructure maturity; honestly leaves some risks (e.g. prompt injection) unsolved; no certification/enforcement; newer and less battle-tested than NIST; two separate maps add complexity for mixed environments

Real Cases

Case	Lesson
CoSAI founding (2023)	Direct competitors (Amazon, Anthropic, Microsoft, OpenAI, etc.) collaborating on shared defensive standards
Google donates SAIF data to CoSAI (Sept 2025)	Google relinquished exclusive control — became community-owned CoSAI-RM tooling
HiddenLayer's universal prompt injection research (CoSAI sponsor)	Adversarial research and defensive framework-building happening inside the same coalition

CoSAI's Nov 2025 releases (model signing, incident response)	The framework actively producing new controls in response to emerging threats
--	---

Part IV — NIST AI RMF vs. Google SAIF

Dimension	NIST AI RMF	Google SAIF
Origin	US government, public consultation	Google, internal security practice
Scope	Broad (fairness, bias, privacy, safety, security)	Narrow, security-specific
Structure	4 Functions / 19 Categories / 72 Subcategories	6 Elements + Risk Map + Agent Map
Language	Governance/policy	Security engineering
Certifiable	No	No
Real-world leverage	Regulatory citation, procurement	Industry coalition (CoSAI)
Best role	Governance umbrella	Technical security layer
Agentic AI coverage	Emerging via Profiles	Dedicated Agent Security Map (2026)
Typical failure mode observed	Strong Govern, weak Measure/Manage	Requires a governance layer on top to be complete

Practical guidance: most mature organizations run both together — NIST RMF as the governance umbrella giving the program authority and legal defensibility, SAIF as the technical playbook giving Measure and Manage real, engineering-grade substance.

Part V — Capstone Activity: SentryHR

Scenario

Vantree Corp (operating in the EU and US) is launching “SentryHR” in 8 weeks — an AI system with three functions: Resume Screening (ranks and auto-rejects the bottom 40% of applicants), an Internal HR Chatbot (answers policy/benefits/pay questions), and SentryFlow, an agentic add-on that auto-updates HR records (address, bank details, leave balance) from conversational requests with no human click required.

Part 1 — Responsible AI

Fairness → Resume Screening: auto-rejecting the bottom 40% with no visibility mirrors the Amazon hiring-AI pattern — biased training data could systematically disadvantage groups undetected.

Safety/Reliability → SentryFlow: an unsupervised agent updating bank details risks acting on a misinterpreted instruction — the Air Canada failure, with real financial consequences.

Part 2 — Governance & Risk Tiering

Function	Tier	Reasoning
Resume Screening	High Risk	Employment is an explicitly named high-stakes EU AI Act domain; hard to reverse once someone is auto-rejected.
HR Chatbot (Q&A only)	Limited Risk	Informational only, like Air Canada's bot — disclosure + accuracy monitoring, not the full high-risk package.
SentryFlow (agentic updates)	High Risk	Real, consequential, autonomous financial-impact action with no human checkpoint — reversibility/blast-radius logic outranks the chatbot's tier.

Trap to flag: tiering “SentryHR” as one system by its most visible feature (the chatbot) would misclassify SentryFlow as limited-risk — the costliest mistake named in the Governance lesson.

Part 3 — Risk Management

Highest-scoring risk: SentryFlow updating the wrong bank account from a misinterpreted request (Likelihood: Medium, Impact: High → High priority).

Treatment: Mitigate. Cap SentryFlow's autonomous authority to low-impact fields only; bank details/leave balance always require the human-review checkpoint (Part 4) — a field-sensitivity threshold, same pattern as the ClaimAI dollar-cap exercise.

Part 4 — Human Review

Checkpoint: any SentryFlow update to a “Restricted” field generates a pending change requiring explicit employee confirmation via a second channel before it is written, logged and reversible for 24 hours.

Maps to SAIF's Agent User Control (explicit approval before consequential action); the field cap = Agent Permissions; the reversible log = Agent Observability — all three working together, as in the Meta case study.

Part 5 — Compliance

FTC Section 5 “unfair practices” authority: deploying resume-screening AI without pre-deployment bias/accuracy testing mirrors FTC v. Rite Aid — a documented bias audit is required before launch. If operating in the EU, the full High Risk conformity assessment package applies before the Aug 2026 deadline.

Part 6 — Data Classification

Classification: Restricted — bank details are regulated financial/personal data. SentryFlow's action pipeline must check field classification before any write, and Restricted fields are hard-blocked from unsupervised writes regardless of model confidence — the “label must travel with the data” principle from Samsung's case.

Part 7 — Frameworks

NIST AI RMF — GOVERN 1.6: log all three SentryHR functions as separate AI-inventory entries, each with its own risk tier, preventing the misclassification trap.

SAIF — Application component, Prompt Injection risk: both the chatbot and SentryFlow take natural-language input, requiring input filtering and instruction/data separation — the same control that would have stopped the Chevrolet \$1-sale incident.

Self-Grading Guide

A strong attempt uses function-specific reasoning throughout (not generic statements) and correctly separates SentryFlow's risk tier from the chatbot's. Core skill tested: tiering and controls must be scoped to the specific function and its specific blast radius, not applied uniformly to a whole system by its most visible feature.

Part VI — Quick-Reference Appendix

Key Definitions

Term	Definition
Responsible AI	Principles an org commits to: fairness, transparency, accountability, privacy, safety, human oversight
AI Governance	Structure/authority enforcing those principles — boards, policy, approval gates
Risk Management	Identify → Assess (likelihood × impact) → Treat (avoid/mitigate/transfer/accept) → Monitor
Human Review	A person with genuine authority (not just presence) checks AI output before it takes effect
Compliance	Binding legal obligations (EU AI Act, US state laws, FTC/SEC) — a floor, not a ceiling
Data Classification	Labeling data by sensitivity so controls follow it everywhere, including into AI pipelines
NIST AI RMF	Voluntary US framework — Govern/Map/Measure/Manage, 19 categories, 72 subcategories
Google SAIF	Google's security-specific framework — 6 elements + Risk Map + Agent Security Map

Core Models to Remember

- Risk Matrix — Likelihood × Impact scoring
- Three Lines of Defense — 1st: builders/operators, 2nd: risk/compliance, 3rd: independent audit
- Residual Risk — what's left after a control; must be documented, never assumed to zero
- KRI vs KPI — KRI = early warning for a specific risk; KPI = whether the risk process itself works
- Risk Tiering (EU AI Act) — Unacceptable → High → Limited → Minimal
- Human Oversight Spectrum — Human Authorization → Human-in-the-loop → Human-on-the-loop
- Automation Bias — trust in reliable AI erodes human vigilance (“moral crumple zone”)
- Conformity Assessment — QMS, Risk Management System, Data Governance, Technical Docs, Logging
- SAIF Agent Controls — Permissions (least privilege), User Control (approval gate), Observability (logging)

Part VII — Conclusion: What Phase 4 Was Really Teaching

None of the six topics in this phase — Responsible AI, Governance, Risk Management, Human Review, Compliance, Data Classification — are really about AI. They are about power, and what happens when a system is given enough power to affect a real person's life without a human directly making that call anymore.

Every case studied across this phase — Air Canada, Robodebt, Rite Aid, Samsung, Cal AI — is the same story wearing a different costume. A company built something genuinely useful. It worked well enough, often enough, that people started trusting it a little more than they should have. Somewhere in the gap between “it works” and “we verified it works, for everyone, every time,” a real person got hurt — denied a fare they were promised, chased for a debt that was never real, accused of a theft they didn't commit.

The moral center of this phase: the frameworks exist because people, left to their own incentives, will ship first and ask “was this safe” second — not out of malice, but out of speed, pressure, and optimism. Every framework learned here — Responsible AI's principles, Governance's structure, NIST's four functions, SAIF's controls — is institutionalized humility: an organization admitting, in advance, that it might be wrong, and building a way to find out before someone pays for it.

The technical center of this phase: almost every control learned does exactly one job — it puts a checkpoint between confidence and consequence. A risk register does it. A human review gate does it. A conformity assessment does it. A data classification label does it. A SAIF agent-permission cap does it. None of these tools make an AI system smarter on their own — they slow the moment down long enough for a human, or a process built by humans, to catch what the system missed. Governance, at its core, is manufactured hesitation in a world that rewards speed.

The pattern worth carrying forward: in every single failure case studied, the checklist already existed on paper. Air Canada had a policy page. Robodebt had a department. Rite Aid had a privacy statement. Samsung had a data classification scheme. The failure was never that nobody thought of it — it was always the same quiet gap between what an organization said it did and what it actually enforced, day to day, when nobody was watching closely and the deadline was close. That gap is where every harm in this entire phase actually lived.

So the one habit worth keeping past all the terminology, past every acronym and every risk matrix: whenever looking at an AI system, don't ask “does a safety policy exist.” Ask “if this thing is wrong right now, at this exact moment, who would notice, how fast, and what happens next.” If that question can't be answered clearly, neither could the people who built Robodebt, and neither could Air Canada's engineers.

Phase 4, in one sentence: *learning to be the person in the room who asks that question before the system ships, not after someone has had to sue to get an answer.*